

# Solicitud de acceso para aprovisionar ambiente STAGING — GORE Valparaíso

Valparaíso, junio de 2026

Para:

Área de TI / administrador de la cuenta AWS

De:

AWNA — proveedor de desarrollo

Cuenta AWS:

184758133903

Usuario IAM ya creado:

dev-team-awna

Objetivo:

Montar un ambiente *staging* (réplica del preprod) para la plataforma de consultas públicas, dentro de la cuenta AWS de la institución.

## 1. Resumen del ambiente a crear

Réplica del ambiente de pre-producción ya operativo. Stack: Laravel (PHP-FPM 8.2) + Nginx sobre una EC2, base de datos MariaDB en RDS, y un bucket S3 para los archivos adjuntos de las consultas ciudadanas.

| Recurso                     | Detalle                                              | Nombre propuesto                  |
|-----------------------------|------------------------------------------------------|-----------------------------------|
| EC2                         | t3.small, Ubuntu 22.04                               | gore-staging-web                  |
| Elastic IP                  | 1 dirección fija                                     | gore-staging-eip                  |
| RDS MariaDB                 | db.t4g.micro, 10.11                                  | gore-staging-db                   |
| S3 bucket                   | adjuntos + artefactos de deploy (sin acceso público) | gore-staging-uploads-184758133903 |
| Security Group web          | 80/443 entrantes                                     | gore-staging-web-sg               |
| Security Group db           | 3306 solo desde el SG web                            | gore-staging-db-sg                |
| IAM role + instance profile | para que la EC2 hable con S3/SSM/Logs                | gore-staging-ec2-role             |
| DB subnet group             | para el RDS                                          | gore-staging-db-subnet-group      |
| SSM Parameter               | secretos de deploy (SecureString)                    | /gore/staging/*                   |

- **Región:** sa-east-1 (São Paulo) — misma que preprod.
- **Tags en todo recurso:** Project=GORE-Valparaiso , Environment=staging , ManagedBy=AWNA .
- **Acceso al servidor:** vía AWS Systems Manager (Session Manager). **No se abre SSH** ni se crean key pairs; el SG web solo expone 80/443.
- **Dominio del servicio:** participa.gobiernovalparaiso.cl (o el subdominio de staging que la institución defina). La administración del DNS y del certificado TLS queda del lado de la institución.

## 2. Acceso solicitado

Ya existe el usuario IAM `dev-team-awna` en la cuenta `184758133903`. Solicitamos asignarle permisos según una de estas opciones:

### Opción 1 — AdministratorAccess **PREFERIDA**

Adjuntar al usuario `dev-team-awna` la política administrada de AWS `AdministratorAccess`. Es la vía más directa para completar el aprovisionamiento y el mantenimiento posterior del ambiente, sin idas y vueltas por permisos faltantes.

### Opción 2 — Política de mínimo privilegio **ALTERNATIVA**

Si la normativa de seguridad institucional no permite acceso de administrador, adjuntar en su lugar la política acotada de la **sección 4**, que restringe la operación a una sola región, a recursos con prefijo `gore-staging-*` y a los servicios estrictamente necesarios.

En ambos casos, las credenciales del usuario se entregan al proveedor por un canal seguro.

## 3. Acotamientos de seguridad (aplican a la Opción 2)

- **Región única:** casi todas las acciones llevan `aws:RequestedRegion = sa-east-1`.
- **Prefijo de nombre:** las acciones de IAM, S3 y Parameter Store solo aplican a recursos `gore-staging-*` / `/gore/staging/*`. El proveedor no puede tocar otros recursos de la cuenta.
- **IAM mínimo:** solo se permite crear/gestionar **un rol** (`gore-staging-ec2-role`) y su instance profile. `PassRole` está restringido a ese rol y solo hacia el servicio EC2.
- **AttachRolePolicy restringido:** solo se puede adjuntar la managed policy `AmazonSSMManagedInstanceCore` (necesaria para administrar el servidor vía SSM), ninguna otra.
- **S3 sin acceso público:** el bucket se crea con *Block Public Access* activo; las descargas se sirven autenticadas por la aplicación, nunca por URL pública.

## 4. Política IAM de mínimo privilegio (Opción 2)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadOnlyDiscovery",
      "Effect": "Allow",
      "Action": [
        "ec2:Describe*",
        "rds:Describe*",
        "rds:ListTagsForResource",
        "s3:ListAllMyBuckets",
        "s3:GetBucketLocation",
        "iam:GetRole",
        "iam:GetInstanceProfile",
        "iam:ListRolePolicies",
        "iam:ListAttachedRolePolicies",
```

```

        "ssm:DescribeInstanceInformation",
        "ssm:ListCommands",
        "ssm:GetCommandInvocation",
        "logs:DescribeLogGroups",
        "sts:GetCallerIdentity"
    ],
    "Resource": "*"
},
{
    "Sid": "ComputeProvisioning",
    "Effect": "Allow",
    "Action": [
        "ec2:RunInstances",
        "ec2:StartInstances",
        "ec2:StopInstances",
        "ec2:TerminateInstances",
        "ec2:ModifyInstanceAttribute",
        "ec2:CreateSecurityGroup",
        "ec2>DeleteSecurityGroup",
        "ec2:AuthorizeSecurityGroupIngress",
        "ec2:AuthorizeSecurityGroupEgress",
        "ec2:RevokeSecurityGroupIngress",
        "ec2:RevokeSecurityGroupEgress",
        "ec2:AllocateAddress",
        "ec2:ReleaseAddress",
        "ec2:AssociateAddress",
        "ec2:DisassociateAddress",
        "ec2:CreateTags",
        "ec2>DeleteTags"
    ],
    "Resource": "*",
    "Condition": { "StringEquals": { "aws:RequestedRegion": "sa-east-1" } }
},
{
    "Sid": "DatabaseProvisioning",
    "Effect": "Allow",
    "Action": [
        "rds:CreateDBInstance",
        "rds:ModifyDBInstance",
        "rds>DeleteDBInstance",
        "rds:CreateDBSubnetGroup",
        "rds>DeleteDBSubnetGroup",
        "rds:AddTagsToResource"
    ],
    "Resource": "*",
    "Condition": { "StringEquals": { "aws:RequestedRegion": "sa-east-1" } }
},
{
    "Sid": "StorageProvisioning",
    "Effect": "Allow",
    "Action": [
        "s3:CreateBucket",
        "s3:PutBucketPolicy",
        "s3:GetBucketPolicy",
        "s3:PutEncryptionConfiguration",
        "s3:PutBucketPublicAccessBlock",
        "s3:PutBucketTagging",
        "s3:PutBucketVersioning",
        "s3:ListBucket",
        "s3:PutObject",
        "s3:GetObject",
        "s3>DeleteObject"
    ],
    "Resource": "*"
},

```

```

    "Resource": [
      "arn:aws:s3::gore-staging-*",
      "arn:aws:s3::gore-staging-*/*"
    ]
  },
  {
    "Sid": "IamForInstanceRole",
    "Effect": "Allow",
    "Action": [
      "iam:CreateRole",
      "iam>DeleteRole",
      "iam:TagRole",
      "iam:PutRolePolicy",
      "iam>DeleteRolePolicy",
      "iam>CreateInstanceProfile",
      "iam>DeleteInstanceProfile",
      "iam:AddRoleToInstanceProfile",
      "iam:RemoveRoleFromInstanceProfile"
    ],
    "Resource": [
      "arn:aws:iam::184758133903:role/gore-staging-*",
      "arn:aws:iam::184758133903:instance-profile/gore-staging-*"
    ]
  },
  {
    "Sid": "AttachSsmManagedPolicyOnly",
    "Effect": "Allow",
    "Action": ["iam:AttachRolePolicy", "iam:DetachRolePolicy"],
    "Resource": "arn:aws:iam::184758133903:role/gore-staging-*",
    "Condition": {
      "ArnEquals": {
        "iam:PolicyARN": "arn:aws:iam::aws:policy/AmazonSSMManagedInstanceCore"
      }
    }
  },
  {
    "Sid": "PassInstanceRoleToEc2Only",
    "Effect": "Allow",
    "Action": "iam:PassRole",
    "Resource": "arn:aws:iam::184758133903:role/gore-staging-ec2-role",
    "Condition": {
      "StringEquals": { "iam:PassedToService": "ec2.amazonaws.com" }
    }
  },
  {
    "Sid": "ParameterStoreForDeploy",
    "Effect": "Allow",
    "Action": [
      "ssm:PutParameter",
      "ssm:GetParameter",
      "ssm:GetParameters",
      "ssm>DeleteParameter"
    ],
    "Resource": "arn:aws:ssm:sa-east-1:184758133903:parameter/gore/staging/*"
  },
  {
    "Sid": "RunDeployCommands",
    "Effect": "Allow",
    "Action": "ssm:SendCommand",
    "Resource": [
      "arn:aws:ssm:sa-east-1::document/AWS-RunShellScript",
      "arn:aws:ec2:sa-east-1:184758133903:instance/*"
    ]
  }
]

```

```

    },
    {
      "Sid": "LogsProvisioning",
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogGroup",
        "logs:CreateLogStream",
        "logs:PutLogEvents",
        "logs:PutRetentionPolicy"
      ],
      "Resource": "arn:aws:logs:sa-east-1:184758133903:log-group:/gore/*"
    }
  ]
}

```

## Justificación por bloque

| Sid                        | Para qué                                                                                                              |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------|
| ReadOnlyDiscovery          | Leer VPC/subnets/recursos existentes para saber dónde crear las cosas. Solo lectura.                                  |
| ComputeProvisioning        | Crear la EC2, sus security groups y la Elastic IP. Limitado a <code>sa-east-1</code> .                                |
| DatabaseProvisioning       | Crear el RDS MariaDB y su subnet group. Limitado a <code>sa-east-1</code> .                                           |
| StorageProvisioning        | Crear y configurar el bucket S3 (solo <code>gore-staging-*</code> ) y subir el script de deploy + <code>.env</code> . |
| IamForInstanceRole         | Crear el rol que usa la EC2 para hablar con S3/SSM/Logs. Solo nombres <code>gore-staging-*</code> .                   |
| AttachSsmManagedPolicyOnly | Hacer la EC2 administrable por SSM. Solo se puede adjuntar la policy de SSM, ninguna otra.                            |
| PassInstanceRoleToEc2Only  | Asociar ese rol a la EC2 al lanzarla. Restringido a ese rol y al servicio EC2.                                        |
| ParameterStoreForDeploy    | Guardar secretos de deploy cifrados. Solo bajo <code>/gore/staging/</code> .                                          |
| RunDeployCommands          | Ejecutar el deploy en la instancia vía SSM (sin SSH).                                                                 |
| LogsProvisioning           | Enviar logs de la app a CloudWatch bajo <code>/gore/</code> .                                                         |

## Anexo A — Permisos que tendrá la EC2 ( `gore-staging-ec2-role` )

Para transparencia: el rol que se crea para la instancia tendrá **solo** estos permisos (policy inline acotada al bucket de staging) más la managed `AmazonSSMManagedInstanceCore` :

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["s3:ListBucket"],
      "Resource": "arn:aws:s3:::gore-staging-uploads-184758133903"
    },
    {
      "Effect": "Allow",
      "Action": ["s3:PutObject", "s3:GetObject", "s3:DeleteObject"],
      "Resource": "arn:aws:s3:::gore-staging-uploads-184758133903/*"
    },
    {
      "Effect": "Allow",
      "Action": ["ses:SendEmail", "ses:SendRawEmail"],
      "Resource": "*"
    }
  ]
}

```

Usar el instance role evita tener que poner llaves de AWS dentro del `.env` de la aplicación (mejora de seguridad respecto del esquema con usuario IAM + access keys). El bloque `ses:*` puede omitirse si en staging el correo se deja en modo simulado.